Risk register

Operational environment:

The bank is located in a coastal area with low crime rates. Many people and systems handle the bank's data—100 on-premise employees and 20 remote employees. The customer base of the bank includes 2,000 individual accounts and 200 commercial accounts. The bank's services are marketed by a professional sports team and ten local businesses in the community. There are strict financial regulations that require the bank to secure their data and funds, like having enough cash available each day to meet Federal Reserve requirements.

Asset	Risk(s)	Description	Likelihood	Severity	Priority
Funds	Business email compromise	*An employee is tricked into sharing confidential information.*	2	3	6 HIGH
	Compromised user database	*Customer data is poorly encrypted.*	2	3	6 HIGH
	Financial records leak	*A database server of backed up data is publicly accessible.*	1	3	3 MODE
	Theft	*The bank's safe is left unlocked.*	1	2	2 LOW
	Supply chain disruption	*Delivery delays due to natural disasters.*	2	2	4 MODE
Notes	*How are security events possible considering the risks the asset faces in its operating environment?*				

Asset: The asset at risk of being harmed, damaged, or stolen.
Risk(s): A potential risk to the organization's information systems and data.
Description: A vulnerability that might lead to a security incident.
Likelihood: Score from 1-3 of the chances of a vulnerability being exploited. A 1 means there's a low likelihood, a 2 means there's a moderate likelihood, and a 3 means there's a high likelihood.
Severity: Score from 1-3 of the potential damage the threat would cause to the business. A 1 means a low severity impact, a 2 is a moderate severity impact, and a 3 is a high severity impact.
Priority: How quickly a risk should be addressed to avoid the potential incident. Use the following formula to calculate the overall score: **Likelihood x Impact Severity = Risk**

Sample risk matrix

Severity

Likelihood	Low 1	Moderate 2	Catastrophic 3
Certain 3	3	6	9
Likely 2	2	4	6
Rare 1	1	2	3

Notes:

1. Business Email Compromise (BEC)

- **Description**: An employee is tricked into sharing confidential information (e.g., login credentials or wire transfer instructions).
- **How It's Possible**: With 120 employees (100 on-premise, 20 remote), phishing emails could exploit human error, especially among remote workers with potentially less secure home setups. Marketing partners (sports teams, local businesses) could also be targeted, providing an entry point if they have access to bank-related communications.
- **Likelihood**: **2 (Moderate)** – Low crime area doesn't reduce phishing risk; large staff increases exposure to social engineering.
- **Severity**: **3 (Catastrophic)** – Funds could be transferred out, disrupting cash reserves and violating Federal Reserve rules.
- **Priority**: 2 × 3 = **6** (High priority – address quickly due to severe financial and regulatory impact).

2. Compromised User Database

- **Description**: Customer data is poorly encrypted, allowing unauthorized access.
- **How It's Possible**: With 2,200 accounts (2,000 individual, 200 commercial), a weakly encrypted database could be breached via remote employee access points

or on-premise system vulnerabilities. Third-party marketing partners might also inadvertently expose data if linked to customer info.

- **Likelihood**: **2 (Moderate)** – Multiple systems and users handling data increase encryption oversight risk, despite low crime rates.
- **Severity**: **3 (Catastrophic)** – Access to account details could lead to fund theft, reputational damage, and regulatory penalties.
- **Priority**: 2 × 3 = **6** (High priority – critical due to scale of customer data and potential fund loss).

3. Financial Records Leak

- **Description**: A database server of backed-up data is publicly accessible.
- **How It's Possible**: Misconfigured servers (e.g., cloud backups for 120 employees' work) could be exploited, especially if remote workers access them over unsecured networks. The coastal location doesn't directly contribute, but reliance on backups for regulatory compliance might lead to oversight in securing them.
- **Likelihood**: **1 (Rare)** – Requires specific misconfiguration, less likely in a regulated environment, but still possible with human error.
- **Severity**: **3 (Catastrophic)** – Leaked records could expose fund details, enabling theft or fraud, and breaching regulations.
- **Priority**: 1 × 3 = **3** (Moderate priority – less likely but devastating if it occurs).

4. Theft

- **Description**: The bank's safe is left unlocked.
- **How It's Possible**: Despite low crime rates, 100 on-premise employees mean multiple people might access the safe. Human error (e.g., forgetting to lock it) could occur during busy operations to meet daily cash requirements.
- **Likelihood**: **1 (Rare)** – Low crime area reduces external theft risk; internal oversight is the main concern.
- **Severity**: **2 (Moderate)** – Cash loss impacts daily operations and compliance but may not drain all funds.
- **Priority**: 1 × 2 = **2** (Low priority – manageable impact in a low-crime setting).

5. Supply Chain Disruption

- **Description**: Delivery delays due to natural disasters affect cash availability.
- **How It's Possible**: Coastal location increases risk of hurricanes or flooding, delaying cash deliveries from the Federal Reserve or armored services. This could hinder meeting daily cash requirements.
- **Likelihood**: **2 (Moderate)** – Coastal areas face seasonal weather risks, though not constant.

- **Severity**: **2 (Moderate)** – Temporary disruption to funds availability; mitigated by reserve planning but still impactful.
- **Priority**: 2 × 2 = **4** (Moderate priority – needs attention due to regulatory implications).